

Chapter 6

Virtual Private Networks

Virtual Private Networks provide secure remote access to individuals and businesses outside your network. VPNs are a cost-effective way to extend your LAN over the Internet to remote networks and remote client computers. They use the Internet to route LAN traffic from one private network to another by encapsulating and encrypting unrestricted LAN traffic inside a standard TCP/IP connection between two VPN-enabled devices. The packets are unreadable by intermediary Internet computers because they are encrypted and they can encapsulate (or carry) any kind of LAN communications, including file and print access, LAN e-mail, and client/server database access. Think of a VPN as a private tunnel through the Internet between firewalls within which any traffic can be passed securely.

Pure VPN systems do not protect your network—they merely transport data. You still need a firewall and other Internet security services to keep your network safe. However, most modern VPN systems are combined with firewalls in a single device.

In This Chapter

- ♦ The primary VPN mechanisms
- ♦ Characteristics of VPNs
- ♦ Common VPN implementations
- ♦ VPN best practices

Virtual Private Networking Explained

Virtual private networks solve the problem of direct Internet access to servers through a combination of the following fundamental components:

- ◆ IP *encapsulation*
- ◆ Cryptographic authentication
- ◆ Data payload encryption

virtual private network

A packet stream that is encrypted, encapsulated, and transmitted over a nonsecure network like the Internet.

All three components must exist in order to have a true VPN. Although cryptographic authentication and data payload encryption may seem like the same thing at first, they are actually entirely different functions and may exist independently of each other. For example, *Secure Sockets Layer (SSL)* performs data payload encryption without cryptographic authentication of the remote user, and the standard Windows logon performs cryptographic authentication without performing data payload encryption.

IP Encapsulation

encapsulation

The insertion of a complete Network layer packet within another Network layer packet. The encapsulated protocol may or may not be the same as the encapsulating protocol and may or may not be encrypted.

Secure Sockets Layer (SSL)

A public key encryption technology that uses certificates to establish encrypted links without exchanging authentication information. SSL is used to provide encryption for public services or services that otherwise do not require identification of the parties involved but where privacy is important. SSL does not perform encapsulation.

When you plan to connect your separated LANs over the Internet, you need to find a way to protect the data traffic that travels between them. Ideally, the computers in each LAN should be unaware that there is anything special about communicating with the computers in the other LANs. Computers outside your virtual network should not be able to snoop on the traffic exchanged between the LANs, nor should they be able to insert their own data into the communications stream. Essentially, you need a private and protected tunnel through the public Internet.

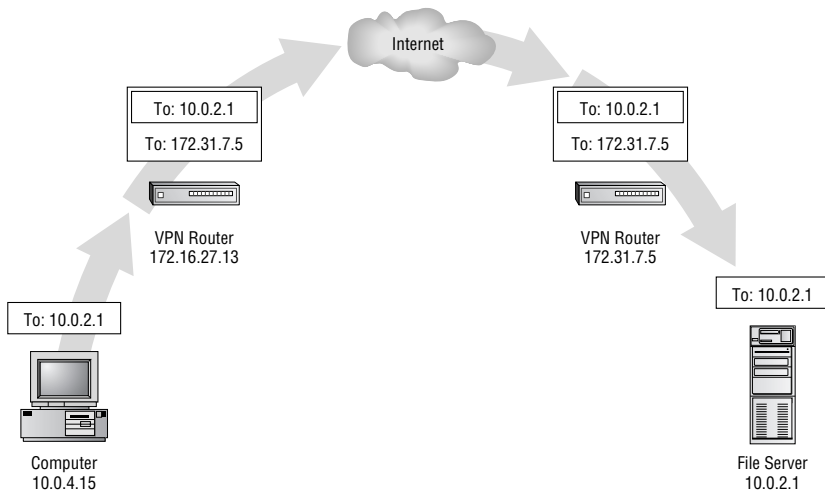
An IP packet can contain any kind of information: program files, spreadsheet data, audio streams, or even other IP packets. When an IP packet contains another IP packet, it is called IP encapsulation, IP over IP, or IP/IP. Encapsulation is the process of embedding packets within other packets at the same Network layer for the purpose of transporting them between the networks where they will be used. For example, you may want to connect two Novell networks that use IPX together over the Internet, so you could encapsulate the IPX packets within IP packets to transport them. The end router would remove the IP packets and insert the IPX packets into the remote network.

Why encapsulate IP within IP? Because doing so makes it possible to refer to a host within another network when the route does not exist. For example, you can't route data to a computer inside the 10.0.0.0 domain because the Internet backbone is configured to drop packets in this range. So connecting your branch office in Chicago (10.1.0.0 network) to your headquarters in San Diego (10.2.0.0 network) cannot be accomplished over the Internet. However, you can encapsulate data exchanged between the two networks over the Internet by connecting to the routers (which have valid public IP addresses) and configuring the destination router to remove the encapsulated traffic and forward it to the interior of your network. This is called clear-channel tunneling.

When the 10.0.0.0/8, 172.16.0.0/12, and 192.168.0.0/16 private network blocks were assigned, routing rules were created to ensure that they could not be routed over the Internet backbone. This provides a good measure of security and prevents conflicts with other networks using the same address block. Private networks should always use these ranges for their internal networking and use Network Address Translation or proxying to access the public Internet.

NOTE

IP encapsulation can make it appear to computers inside the private network that distant networks are actually adjacent—separated from each other by a single router. But they are actually separated by many Internet routers and gateways that may not even use the same address space because both internal networks are using address translation.



The tunnel endpoint—be it a router, firewall, VPN appliance, or a server running a tunneling protocol—will receive the public IP packet, remove the internal packet contained within it, decrypt it (assuming that it's encrypted—it doesn't have to be), and then apply its routing rules to send the embedded packet on its way in the internal network.

Cryptographic Authentication

Cryptographic authentication is used to securely validate the identity of the remote user so the system can determine what level of security is appropriate for that user. VPNs use cryptographic authentication to determine whether or not the user can participate in the encrypted tunnel and may also use the authentication to exchange the secret or public key used for payload encryption.

Many different forms of cryptographic authentication exist, and the types used by VPNs vary from vendor to vendor. In order for two devices from different vendors to be compatible, they must support the same authentication and payload encryption algorithms and implement them in the same way. Your best bet for determining compatibility is to perform a Web search to make sure all the devices you want to use are actually compatible.

Data Payload Encryption

wide area networks (WANs)

Networks that span long distances using digital telephony trunks like dedicated leased lines, Frame Relay, satellite, or alternative access technologies to link local area networks.

Data payload encryption is used to obfuscate the contents of the encapsulated data without relying on encapsulating an entire packet within another packet. In that manner, data payload encryption is exactly like normal IP networking except that the data payload has been encrypted. Payload encryption obfuscates the data but does not keep header information private, so details of the internal network can be ascertained by analyzing the header information.

Data payload encryption can be accomplished using any one of a number of secure cryptographic methods, which differ based on the VPN solution you chose.

In the case of VPNs, because the “real” traffic is encapsulated as the payload of the tunnel connection, the entire private IP packet, header and all, is encrypted. It is then carried as the encrypted payload of the otherwise normal tunnel connection.

Characteristics of VPNs

When you consider establishing a VPN for your company, you should understand the advantages and disadvantages of VPNs when compared with traditional *local area networks (LANs)* and *wide area networks (WANs)*.

VPNS are cheaper than WANs. A single dedicated leased line between two major cities costs many thousands of dollars per month, depending on the amount of bandwidth you need and how far the circuit must travel. A company’s dedicated connection to an ISP is usually made with a leased line of this sort, but the circuit is much shorter—usually only a few miles—and an IP connection is usually already in place and budgeted for. With a VPN, only one leased line to an ISP is required, and it can be used for both Internet and VPN traffic. ISPs can be selected for proximity to your operation to reduce cost.

VPNs are easier to establish. It typically takes at least two months to get a traditional WAN established using *dedicated leased lines* or *Frame Relay*, and a lot of coordination with the various telecommunications companies is usually involved. In contrast, you can establish a VPN wherever an Internet connection exists, over any mix of circuits, and using whatever technology is most cost effective in each locale.

local area networks (LANs)

High-speed (short distance) networks existing (usually) within a single building. Computers on the same local area network can directly address one another using Data Link layer protocols like Ethernet or Token Ring and do not require routing in order to reach other computers on the same LAN.

dedicated leased lines

Digital telephone trunk lines leased from a telephone company and used to transmit digitized voice or data.

VPNs are slower than LANs. You will not get the same performance out of your VPN that you would with computers that share the same LAN. Typical LANs transfer data at 10 or 100Mbps, while the Internet limits VPNs to the slowest of the links that connect the source computer to the destination computer. Of course, WANs are no different; if you linked the same LANs directly via *T1 leased lines*, you would still have a 1.5Mbps (each way) bandwidth limit. Furthermore, you will find that Internet congestion between your VPN endpoints may put a serious drag on your network. The best way to take care of this problem is to use the same national or global ISP to connect your systems. This way, all your data will travel over its private network, thus avoiding the congested *commercial Internet exchange* network access points.

VPNs are less reliable than WANs. Unexpected surges in Internet activity can reduce the bandwidth available to users of your VPN. Internet outages are more common than Telco circuit outages, and (recently) hacking and Internet worm activity has begun to eat up a considerable amount of bandwidth on the Internet, creating weather-like random effects. How susceptible your VPN is to these problems depends largely on the number of ISPs between your systems.

VPNs are less secure than isolated LANs or WANs. Before a hacker can attack your network, there must be a way for the hacker to reach it. VPNs require Internet connections, whereas WANs don't, but most networks are connected to the Internet anyway. A VPN is marginally more vulnerable to network intrusion than a LAN or WAN that is connected to the Internet because the VPN protocol's service port is one more vector for the hacker to try to attack.

Frame Relay

A Data Link layer packet-switching protocol that emulates a traditional point-to-point leased line. Frame Relay allows the telephone companies to create a permanent virtual circuit between any two points on their digital networks by programming routes into their Frame Relay routers.

T1 leased lines

The traditional designator for the most common type of digital leased line. T1 lines operate at 1.544Mbps (as a single channel, or 1.536Mbps when multiplexed into 24 channels) over two pairs of category 2 twisted-pair wiring.

commercial Internet exchange (CIX)

One of an increasing number of regional datacenters where the various tier-1 ISPs interconnect their private networks via TCP/IP to form the nexus of the Internet.

Common VPN Implementations

Although theoretically any cryptographically strong algorithm can be used with some form of IP encapsulation to create a VPN, a few market-leading implementations have arisen—because they are easy to splice together from existing separate tools, because they are the agreed upon standards of numerous small vendors, or because a large vendor implemented them and incorporated them for free into ubiquitous products like operating systems. The common VPN implementations are as follows:

- ◆ IPsec tunnel mode
- ◆ L2TP
- ◆ PPTP
- ◆ PPP/SSL or PPP/SSH

Each of these common implementations is detailed in the following sections.

security association (SA)

A set of cryptographic keys and protocol identifiers programmed into a VPN endpoint to allow communication with a reciprocal VPN endpoint. IKE allows security associations to be negotiated on-the-fly between two devices if they both know the same secret key.

NetBEUI

Microsoft's original networking protocol that allows for file and resource sharing but which is not routable and is therefore limited to operation on a single LAN. As with any protocol, NetBEUI can be encapsulated within a routable protocol to bridge distant networks.

NOTE

Internet Key Exchange (IKE)

A protocol that allows the exchange of IPSec security associations based on trust established by knowledge of a private key.

IPSec

IPSec is the IETF's standard suite for secure IP communications that relies on encryption to ensure the authenticity and privacy of IP communications. IPSec provides mechanisms that can be used to do the following:

- ◆ Authenticate individual IP packets and guarantee that they are unmodified.
- ◆ Encrypt the payload (data) of individual IP packets between two end systems.
- ◆ Encapsulate a TCP or UDP socket between two end systems (hosts) inside an encrypted IP link (tunnel) established between intermediate systems (routers) to provide virtual private networking.

IPSec performs these three functions using two independent mechanisms: Authenticated Headers (AH) to provide authenticity and Encapsulating Security Payload (ESP) to encrypt the data portion of an IP Packet. These two mechanisms may be used together or independently.

Authenticated Headers work by computing a checksum of all of the TCP/IP header information and encrypting the checksum with the public key of the receiver. The receiver then decrypts the checksum using its secret key and checks the header against the decrypted checksum. If the computed checksum is different than the header checksum, it means that either the decryption failed because the key was wrong or the header was modified in transit. In either case, the packet is dropped.

Because NAT changes header information, IPSec Authenticated Headers cannot be reliably passed through a network address translator (although some network address translators can perform translation automatically for a single internal host). ESP can still be used to encrypt the payload, but support for ESP without AH varies among implementations of IPSec. These variations account for the incompatibilities between some vendors' IPSec VPN implementations.

With Encapsulating Security Payload, the transmitter encrypts the payload of an IP packet using the public key of the receiver. The receiver then decrypts the payload upon receipt and acts accordingly.

IPSec can operate in one of two modes: transport mode, which works exactly like regular IP except that the headers are authenticated (AH) and the contents are encrypted (ESP), or tunnel mode, where complete IP packets are encapsulated inside AH/ESP packets to provide a secure tunnel. Transport mode is used for providing secure or authenticated communication over public IP ranges between any Internet-connected hosts for any purpose, while tunnel mode is used to create VPNs.

Because IPSec has problems traversing NATs, and because NATs have become ubiquitous, the deployment of IPSec as a common VPN platform is stalling. Vendors have come up with various solutions, the most common of which is to further encapsulate entire VPN sessions inside UDP packets that can be network

address translated. These solutions are proprietary and do not necessarily work well across different device vendors. An emerging standard for UDP encapsulation of IPSec VPN traffic is helping to sort out these problems, but it will be a few years before all vendors are compatible with the standard.

Internet Key Exchange

IPSec uses the concept of the *security associations (SAs)* to create named combinations of keys, identifiers of cryptographic algorithms, and rules to protect information for a specific function. The policy (rule) may indicate a specific user, host IP address, or network address to be authenticated, or it may specify the route for information to take.

In early IPSec systems, public keys for each SA were manually installed via file transfer or by actually typing them in. For each SA, each machine's public key had to be installed on the reciprocal machine. As the number of security associations a host required increased, the burden of manually keying machines became seriously problematic—IPSec was used primarily only for point-to-point systems because of this.

The *Internet Key Exchange (IKE)* protocol obviates the necessity to manually key systems. IKE uses private key security to validate the remote firewall's authority to create an IPSec connection and to securely exchange public keys. IKE is also capable of negotiating a compatible set of encryption protocols with a destination host, so administrators don't have to know exactly which encryption protocols are supported on the destination host. Once the public keys are exchanged and the encryption protocols are negotiated, a security association is automatically created on both hosts and normal IPSec communications can be established. With IKE, each computer that needs to communicate via IPSec needs only to be keyed with a single private key. That key can be used to create an IPSec connection to any other IPSec host that has the same private key.

L2TP

Layer 2 Tunneling Protocol (L2TP) is an extension to the *Point-to-Point Protocol (PPP)* that allows the separation of the Data Link layer endpoint and the Physical layer network access point. PPP is the protocol used when you dial into the Internet with a modem—it transfers data from your computer to a remote access server at your ISP, which then forwards the data on to the Internet.

The separation between Data Link layer endpoints and Physical layer endpoints means that, for example, you could outsource a *dial-up modem bank* to your phone company and have it forward the data in the modem conversation to you so that your own routers can extract it and determine what to do with it. You save the cost of expensive telephone banks while retaining the ability to connect directly to dial-up users.

Layer 2 Tunneling Protocol (L2TP)

An industry-standard protocol for separating the Data Link layer transmission of packets from the flow control, session, authentication, compression, and encryption protocols. L2TP is typically used for remote access applications and is the successor to PPP.

Point-to-Point Protocol (PPP)

A protocol originally developed to allow modem links to carry different types of Network layer protocols like TCP/IP, IPX, NetBEUI, and AppleTalk. PPP includes authentication and protocol negotiation as well as control signals between the two points, but does not allow for addressing because only two participants are involved in the communication.

dial-up modem bank

A collection of modems that are connected to a high-speed network and are dedicated to the task of answering calls from the modems of end users, thereby connecting them to the network.

Internetwork Packet Exchange (IPX)

The routable LAN protocol developed by Novell for its NetWare server operating system. IPX is very similar to TCP/IP, but it uses the Data Link layer Media Access Control (MAC) address for unique addressing rather than a user-configured address and is therefore easier to configure. IPX routes broadcasts around the entire network and is therefore unsuitable in larger networks.

AppleTalk

The proprietary file and resource sharing mechanism for Apple Macintosh computers. Recent versions of the Mac OS are also compatible with the Windows (SMB) file sharing protocol.

Asynchronous Transfer Mode (ATM)

A packet-switched Data Link layer framing protocol used for high-speed digital circuits that is compatible across a wide range of physical circuit speeds. ATM is typically used for intercity and metropolitan area circuits.

Like PPP, L2TP includes a mechanism for secure authentication using a number of different authentication mechanisms that can be negotiated among the connecting computers. L2TP is a tunneling protocol—its purpose is to embed higher-layer packets into a protocol that can be transported between locations. Unlike pure IPsec tunneling, L2TP can support any interior protocol, including *Internetwork Packet Exchange (IPX)*, *AppleTalk*, and *NetBEUI*, so it can be used to create links over the Internet for protocols that are not Internet compatible. L2TP packets can also be encrypted using IPsec.

L2TP is also not a transport protocol—it can be transported over any Data Link layer protocol (ATM, Ethernet, etc.) or Network layer protocol (IP, IPX, etc.). L2TP is essentially an “any-to-any” shim that allows you to move any protocol over any other protocol in a manner that can be negotiated between compatible endpoints.

You may have noticed that L2TP supports the three requisite functions to create a VPN: authentication, encryption, and tunneling. Microsoft and Cisco both recommend it as their primary method for creating VPNs. It is not yet supported by most firewall vendors, however, and does not transit network address translators well.

PPTP

PPTP was Microsoft’s first attempt at secure remote access for network users. Essentially, PPTP creates an encrypted PPP session between two TCP/IP hosts. Unlike L2TP, PPTP operates only over TCP/IP—L2TP can operate over any packet transport, including Frame Relay and *Asynchronous Transfer Mode (ATM)*. PPTP does not use IPsec to encrypt packets—rather it uses a hash of the user’s Windows NT password to create a private key between the client and the remote server. This (in the 128-bit encrypted version) is salted with a random number to increase the encryption strength. Because PPTP does not use authenticated headers, it passes through network address translators easily and is quite simple to forward from a public address to an interior PPTP server on the private network. All versions of Windows, all common distributions of Linux, and the latest versions of Mac OS X include PPTP clients that operate as part of the operating system and are exceptionally easy to configure. Because of its ubiquity, routing flexibility, and ease of use, it is probably the most common form of VPN.

NOTE

L2TP is the successor to PPTP—it is more generalized in that it works over any packet transport, and its encryption strength is far stronger thanks to IPsec encryption. PPTP should be used for legacy compatibility, but new installations should favor L2TP for secure remote access.

Open-source developers for Unix implementations including Linux and the various *open source* BSD derivatives have implemented PPTP to support inexpensive encrypted tunnels with Windows clients. Both client-side and server-side

implementations are available that interoperate well with Microsoft's implementation of PPTP. So, while IPSec is still the future of VPNs, PPTP is a pragmatic "here now" solution to cross-platform VPN interoperability.

PPP/SSL or PPP/SSH

PPP (Point to Point Protocol) over Secure Sockets Layer (SSL) or *Secure Shell* (SSH) are two common methods that Unix and open-source operating system administrators employ to create VPNs "on-the-fly." Both methods, which might be considered "hacks" in the Windows world, employ a clever combination of an existing encrypted transport (SSL or SSH) and an existing tunnel provider, PPP.

PPP

Point-to-Point Protocol was originally designed to support multiprotocol transport over serial lines. Originally, the dial-up access world was clearly split into operating system-specific camps; Windows, which supported only Net-BIOS connections over modem links; Macintosh, which supported only Apple-Talk connections; Unix, which supported only Serial Line Internet Protocol (SLIP) connections; and NetWare, which supported only IPX connections to NetWare servers. PPP was developed originally to abstract the protocol away from the connection so that a serial line connection could be established that would then be able to carry any Network layer protocol. So, essentially, PPP creates a Data Link layer connection between endpoints over which a Network layer protocol can be transported—or, in other words, a tunnel.

Because of its flexibility, PPP can be used to create a connection between any two IP systems and then transport IP over the PPP connection. This is an easy way to create IP/IP tunnels without specific operating system support for tunneling. But PPP performs no encryption, so while tunneling is useful, it's not secure.

SSL

Secure Sockets Layer is a public key encryption protocol developed by Netscape to support secure web browsing. SSL does not perform authentication—its only purpose is to encrypt the contents of a connection between a client and a public server. So SSL performs an essentially "pure" public key exchange—when a client connects to the SSL port on a server, the server transmits an encryption key that the client uses to encrypt its data stream. The client does the same thing, so a bidirectional secure stream can be established. This stream is used to exchange a pair of randomly generated secret keys so that high-speed encryption algorithms can be used.

SSH

SSH is the Unix secure shell, which was originally designed to shore up the serious security flaws in Telnet. Telnet allowed users to connect to a Unix host and establish a remote text console from which the host could be operated. Because Telnet

open source

Software produced by a free association of programmers who have all agreed to make their work available at no cost along with the original source code. Actual licensing terms vary, but generally there are stipulations that prevent the code from being incorporated into otherwise copyrighted software.

Secure Shell

A secure version of Telnet that includes authentication and encryption based on public keys.

hails from those early days when hackers did not have access to the Internet, it performs no encryption and only simple unencrypted password challenges. SSH shores this up by performing secure authenticated logons using perfect forward secrecy and then by encrypting the communication session between the client and the host. Like most Unix applications, SSH can accept redirection to and from other running applications by correctly constructing “pipes” on the Unix command prompt. Unlike SSL, SSH uses secret key encryption so both parties must know the secret key in advance to establish a connection.

Securing PPP

Given the PPP command built into most modern implementations of Unix and either SSH or SSL, it’s a simple task to construct a command that can direct the establishment of an encrypted tunnel and pipe its input and output streams to the PPP command. This, in essence, creates a virtual network adapter on each host system that is connected via PPP to the remote host, which is in turn encrypted by either SSH or SSL.

The security of a system like this is based mostly on the security of the underlying cryptosystem—SSL or SSH. If the administrator has done his homework and knows for certain the identity of the hosts involved in the connection, these connection methods can be as secure as PPTP or L2TP.

NOTE

Although the implementation differs in the way authentication is handled, PPTP is analogous to PPP over SSL and provides basically equivalent security.

VPN Best Practices

Virtual private networks are convenient, but they can also create gaping security holes in your network. The following practices will help you avoid trouble.

Use a real firewall. As with every other security component, the best way to ensure that you have comprehensive security is to combine security functions on a single machine. Firewalls make ideal VPN endpoints because they can route translated packets between private systems. If your VPN solution weren’t combined with your NAT solution, you’d have to open some route through your firewall for the VPN software or the NAT software, either of which could create a vector for attack.

Real firewalls are also most likely to use provably secure encryption and authentication methods, and their vendors are more likely to have implemented the protocol correctly. Ideally, you’d be able to find an open-source firewall whose source code you (and everyone else) could inspect for discernable problems.

Secure the base operating system. No VPN solution provides effective security if the operating system of the machine is not secure. Presumably,

the firewall will protect the base operating system from attack, which is another reason you should combine your VPN solution with your firewall.

Implementing any sort of VPN endpoint on a server without also implementing strong filtering is asking for trouble—without a secure base operating system, the VPN can be easily hacked to gain access to your network from anywhere.

Use a single ISP. Using a single ISP to connect all the hosts acting as tunnel endpoints will increase both the speed and security of your tunnel because ISPs will keep as much traffic as they possibly can on their own networks. This means that your traffic is less exposed to the Internet as a whole and that the routes your ISP uses will avoid congestion points in the Internet. When you use multiple ISPs, they will most likely connect through the commercial Internet exchange network access points—the most congested spots on the Internet. This practically guarantees that your VPN tunnel will be slow, often uselessly slow for some protocols.

Choose an ISP that can also provide dial-up service to your remote users who need it. Alternatively, you may choose a local ISP that is downstream from your national ISP because they are also on the national ISP's network and many national ISPs don't provide dial-up service.

Use packet filtering to reject unknown hosts. You should always use packet filtering to reject connection attempts from every computer except those you've specifically set up to connect to your network remotely. If you are creating a simple network-to-network VPN, this is easy—simply cross-filter on the foreign server's IP address and you'll be highly secure. If you're providing VPN access to remote users whose IP address changes dynamically, you'll have to filter on the network address of the ISP's dial-up TCP/IP domain. Although this method is less secure, it's still considerably more secure than allowing the entire Internet to attempt to authenticate with your firewall.

Use public key encryption and secure authentication. Public key authentication is considerably more secure than the simple, shared secret authentication used in some VPN implementations—especially those that use your network account name and password to create your secret key the way PPTP does. Select VPN solutions that use strong public key encryption to perform authentication and to exchange the secret keys used for bulk stream encryption.

Microsoft's implementation of PPTP is an example of a very insecure authentication method. PPTP relies upon the Windows NT account name and password to generate the authentication hash. This means that anyone with access to a valid name and password (for example, if one of your users has

visited a malicious website that may have initiated a surreptitious password exchange with Internet Explorer) can authenticate with your PPTP server.

Compress before you encrypt. You can get more data through your connection by stream compressing the data before you put it through your VPN. Compression works by removing redundancy. Since encryption salts your data with nonredundant random data, properly encrypted data cannot be compressed. This means that if you want to use compression, you must compress before you encrypt. Any VPN solution that includes compression will automatically take care of that function for you.

Secure remote hosts. Make sure the remote access users who connect to your VPN using VPN client software are properly secured. Hacking Windows home computers from the Internet is depressingly easy and can become a vector directly into your network if that home computer is running a VPN tunnel to it. Consider the case of a home user with more than one computer who is using a proxy product like WinGate to share their Internet connection and also has a VPN tunnel established over the Internet to your network. Any hacker on the planet could then proxy through the WinGate server directly into your private network. This configuration is far more common than it should be.

The new breed of Internet worms that exploit bugs in operating systems are running rampant on the cable modem and DSL networks of home users right now. Here they find a garden of unpatched default installations of Windows. These clients are suddenly the Typhoid Marys of the corporate world, propagating worms to the interior of corporate networks through their VPN connections.

Alert users to the risks of running a proxy or web server (or any other unnecessary service) software on their home machines. Purchase personal firewall software or inexpensive DSL/cable routers to protect each of your home users; remember that when they're attached to your network, a weakness in their home computer security is a weakness in your network security.

WARNING

Be especially vigilant about laptops—they travel from network to network and easily pick up worms from unprotected connections. Use strong software firewalls such as Norton Internet Security to protect them.

Prefer compatible IPSec with IKE VPNs. To achieve the maximum flexibility in firewalls and remote access software, choose IPSec with IKE VPN solutions that have been tested to work correctly with each other. IPSec with IKE is the closest thing to a standard encryption protocol there is, and although compatibility problems abound among various implementations, it is better than being locked into a proprietary encryption protocol that in turn locks you into a specific firewall vendor.

IPSec users may have problems connecting from hotels and clients that are behind their own firewalls. To solve this problem, use IPSec implementations that can encapsulate IPSec within UDP, or fall back to using PPTP, which has no problems with network address translation.

Terms to Know

AppleTalk	local area network (LAN)
Asynchronous Transfer Mode (ATM)	NetBEUI
commercial Internet exchange (CIX)	open source
dedicated leased lines	Point-to-Point Protocol (PPP)
dial-up modem bank	Secure Shell (SSH)
encapsulation	Secure Sockets Layer (SSL)
Frame Relay	security associations (SA)
Internet Key Exchange (IKE)	T1 leased lines
Internetwork Packet Exchange (IPX)	virtual private network (VPN)
Layer 2 Tunneling Protocol (L2TP)	wide area network (WAN)

Review Questions

1. What are the three fundamental methods implemented by VPNs to securely transport data?
2. What is encapsulation?
3. Why are VPNs easier to establish than WANs?
4. What is the difference between IPSec transport mode and IPSec tunnel mode?
5. What functions does IKE perform?
6. What common sense measure can you take to ensure the reliability and speed of a VPN?
7. What is the most common protocol used among VPN vendors?
8. What's the primary difference between L2TP and PPP?
9. What encryption algorithm is specified for L2TP?